



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://172.30.19.1:5601> <https://content-signature-2.cdn.mozilla.net>
<http://172.30.19.1:5601>

Generated on Sun, 26 Jul 2026 17:53:33

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	2
Informational	3
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	4
Directory Browsing	Medium	Systemic
HTTP Only Site	Medium	1
Missing Anti-clickjacking Header	Medium	2
Vulnerable JS Library	Medium	1
Timestamp Disclosure - Unix	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	16
Modern Web Application	Informational	4
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page

	— covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://172.30.19.1:5601
Node Name	http://172.30.19.1:5601
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.1:5601/
Node Name	http://172.30.19.1:5601/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.1:5601/app/kibana
Node Name	http://172.30.19.1:5601/app/kibana
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.1:5601/status
Node Name	http://172.30.19.1:5601/status
Method	GET
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Directory Browsing
Description	It is possible to view the directory listing. Directory listing may reveal hidden scripts, include files, backup source files, etc. which can be accessed to read sensitive information.
URL	http://172.30.19.1:5601/bundles/node_modules/
Node Name	http://172.30.19.1:5601/bundles/node_modules/
Method	GET
Attack	http://172.30.19.1:5601/bundles/node_modules/
Evidence	Parent Directory
Other Info	
URL	http://172.30.19.1:5601/bundles/node_modules/font-awesome/
Node Name	http://172.30.19.1:5601/bundles/node_modules/font-awesome/
Method	GET
Attack	http://172.30.19.1:5601/bundles/node_modules/font-awesome/
Evidence	Parent Directory
Other Info	
URL	http://172.30.19.1:5601/bundles/src/ui/public/
Node Name	http://172.30.19.1:5601/bundles/src/ui/public/
Method	GET
Attack	http://172.30.19.1:5601/bundles/src/ui/public/
Evidence	Parent Directory
Other Info	
Instances	Systemic
Solution	Disable directory browsing. If this is required, make sure the listed files does not induce risks.
Reference	https://httpd.apache.org/docs/current/mod/core.html#options
CWE Id	548
WASC Id	48
Plugin Id	0

Medium	HTTP Only Site
Description	The site is only served under HTTP and not HTTPS.
URL	http://172.30.19.1:5601/
Node Name	https://172.30.19.1:5601/
Method	GET
Attack	
Evidence	
Other Info	Failed to connect. ZAP attempted to connect via: https://172.30.19.1:5601/

Instances	1
Solution	Configure your web or application server to use SSL (https).
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html https://letsencrypt.org/
CWE Id	311
WASC Id	4
Plugin Id	10106

Medium	Missing Anti-clickjacking Header
---------------	---

Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://172.30.19.1:5601
Node Name	http://172.30.19.1:5601
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.1:5601/
Node Name	http://172.30.19.1:5601/
Method	GET
Attack	
Evidence	
Other Info	
Instances	2
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Vulnerable JS Library
---------------	------------------------------

Description	The identified library appears to be vulnerable.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	* jQuery JavaScript Library v2.1.4

Other Info	The identified library jquery, version 2.1.4 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2015-9251 CVE-2019-11358 https://github.com/jquery/jquery/issues/2432 http://research.insecurelabs.org/jquery/test/ http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://172.30.19.1:5601/api/status
Node Name	http://172.30.19.1:5601/api/status
Method	GET
Attack	
Evidence	1533203125
Other Info	1533203125, which evaluates to: 2018-08-02 09:45:25.
Instances	1
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://172.30.19.1:5601
Node Name	http://172.30.19.1:5601
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.1:5601/
Node Name	http://172.30.19.1:5601/
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.1:5601/api/status
Node Name	http://172.30.19.1:5601/api/status
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.1:5601/bundles/src/ui/public/images/elk.ico
Node Name	http://172.30.19.1:5601/bundles/src/ui/public/images/elk.ico
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

URL	http://172.30.19.1:5601/bundles/statusPage.style.css?v=10247
Node Name	http://172.30.19.1:5601/bundles/statusPage.style.css (v)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	dataType: null, username: null, password:
Other Info	The following pattern was used: \bUSERNAME\b and was detected in likely comment: "/* timeout: 0, data: null, dataType: null, username: null, password: null, cache: null, throws: false, t", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET

Attack	
Evidence	the database by an administrator.</p> * </d>
Other Info	The following pattern was used: \bADMINISTRATOR\b and was detected in likely comment: <code>"/**</code> * @ngdoc service * @name \$interpolate * @kind function * * @requires \$parse * @requires ", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	to global for call from export context
Other Info	The following pattern was used: \bFROM\b and was detected 425 times, the first in likely comment: <code>"// bind timers to global for call from export context"</code> , see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	// FIXME: Couldn't find a wa
Other Info	The following pattern was used: \bFIXME\b and was detected in likely comment: <code>"// FIXME: Couldn't find a way to test for browser compatibility without"</code> , see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	// IE 8- don't enum bug keys
Other Info	The following pattern was used: \bBUG\b and was detected 36 times, the first in likely comment: <code>"// IE 8- don't enum bug keys"</code> , see evidence field for the suspicious comment /snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	// See http://bugs.jquery.com/ticket/1

Other Info	The following pattern was used: \bBUGS\b and was detected 13 times, the first in likely comment: "// See http://bugs.jquery.com/ticket/13378", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	// later invocations of the
Other Info	The following pattern was used: \bLATER\b and was detected 34 times, the first in likely comment: "// later invocations of the iterator.", see evidence field for the suspicious comment /snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	// locations where there is no enclosi
Other Info	The following pattern was used: \bWHERE\b and was detected 72 times, the first in likely comment: "// locations where there is no enclosing try statement.", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	a id="link-5" name="xxx" ng-click="value =
Other Info	The following pattern was used: \bXXX\b and was detected 3 times, the first in likely comment: "/* * @ngdoc directive * @name ngHref * @restrict A * @priority 99 * * @description * Using Angular markup like `{", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	alue('ADMIN_USER', 'admin'); * * \$provi
	The following pattern was used: \bADMIN\b and was detected in likely comment: "/* * @ngdoc method

Other Info	* @name \$provide#value * @description * * Register a value service with the {@link auto.\$inject", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	bject The object to query. * @param {Ar
Other Info	The following pattern was used: \bQUERY\b and was detected 105 times, the first in likely comment: "/* * The base implementation of `get` without support for string paths * and default values. * * @priva", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	ject.observe(models.todo, todoChanges);
Other Info	The following pattern was used: \bTODO\b and was detected 45 times, the first in likely comment: "/* * Creates a debounced function that delays invoking `func` until after `wait` * milliseconds have elapsed since ", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	nt application with debug information turned
Other Info	The following pattern was used: \bDEBUG\b and was detected 11 times, the first in likely comment: "/* * @ngdoc function * @name angular.reloadWithDebugInfo * @module ng * @description * Use this function to reload th", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247

Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	or POS matching in `select`
Other Info	The following pattern was used: <code>\bSELECT\b</code> and was detected 38 times, the first in likely comment: <code>"// We use this for POS matching in `select`"</code> , see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.1:5601/bundles/commons.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/commons.bundle.js (v)
Method	GET
Attack	
Evidence	<code>rs = [* { 'user': 'barney', 'activ</code>
Other Info	The following pattern was used: <code>\bUSER\b</code> and was detected 151 times, the first in likely comment: <code>"/**</code> <code>* This method is like <code>_.find` except that it returns the index of the first</code></code></p> <p><code>* element <code>predicate` returns truth"</code>, see evidence field for the suspicious comment/snippet.</code>
URL	http://172.30.19.1:5601/bundles/statusPage.bundle.js?v=10247
Node Name	http://172.30.19.1:5601/bundles/statusPage.bundle.js (v)
Method	GET
Attack	
Evidence	<code>} * includes code from: * - elasticsear</code>
Other Info	The following pattern was used: <code>\bFROM\b</code> and was detected in likely comment: <code>"/**</code> <code>* Test entry file</code> <code>*</code> <code>* This is programatically created and updated, do not modify</code> <code>*</code> <code>* context: {"env":"production"},"", see evidence field for the suspicious comment/snippet.</code>
Instances	16
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://172.30.19.1:5601
Node Name	http://172.30.19.1:5601

Method	GET
Attack	
Evidence	<script>var hashRoute = '/app/kibana'; var defaultRoute = '/app/kibana'; var hash = window.location.hash; if (hash.length) { window.location = hashRoute + hash; } else { window.location = defaultRoute; }</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://172.30.19.1:5601/
Node Name	http://172.30.19.1:5601/
Method	GET
Attack	
Evidence	<script>var hashRoute = '/app/kibana'; var defaultRoute = '/app/kibana'; var hash = window.location.hash; if (hash.length) { window.location = hashRoute + hash; } else { window.location = defaultRoute; }</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://172.30.19.1:5601/app/kibana
Node Name	http://172.30.19.1:5601/app/kibana
Method	GET
Attack	
Evidence	<script>window.__KBN__ = {"app":{"id":"statusPage","title":"Server Status","main":"plugins/statusPage/statusPage","url":"/status"},"nav":[{"id":"kibana","title":"Kibana","description":"the kibana you know and love","main":"plugins/kibana/kibana","url":"/app/kibana"},"version":"4.6.6","buildNum":10247,"buildSha":"d344b80b0fe4183467093aedbeed7a5351a0f537","basePath":"","vars":{"kbnIndex":"kibana","esRequestTimeout":30000,"esShardTimeout":0,"esApiVersion":"2.0"}};</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://172.30.19.1:5601/status
Node Name	http://172.30.19.1:5601/status
Method	GET
Attack	
Evidence	<script>window.__KBN__ = {"app":{"id":"statusPage","title":"Server Status","main":"plugins/statusPage/statusPage","url":"/status"},"nav":[{"id":"kibana","title":"Kibana","description":"the kibana you know and love","main":"plugins/kibana/kibana","url":"/app/kibana"},"version":"4.6.6","buildNum":10247,"buildSha":"d344b80b0fe4183467093aedbeed7a5351a0f537","basePath":"","vars":{"kbnIndex":"kibana","esRequestTimeout":30000,"esShardTimeout":0,"esApiVersion":"2.0"}};</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	4
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational

User Agent Fuzzer

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://172.30.19.1:5601/api/status
Node Name	http://172.30.19.1:5601/api/status
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://172.30.19.1:5601/api/status
Node Name	http://172.30.19.1:5601/api/status
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://172.30.19.1:5601/api/status
Node Name	http://172.30.19.1:5601/api/status
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104